

XSS from 192.168.20.10

*Investigation `inv\_772ce62877dd44b58bd431ccea38b4d5` · alert `alr\_aa8e3fe4c88c4a1890700820da043650`
· generated 2026-09-24T05:16:25.770752+00:00*

Severity: HIGH

- base severity for category Web-Based = high

Alert summary

- _id: alr_aa8e3fe4c88c4a1890700820da043650
- attack_type: XSS
- category: Web-Based
- predicted_label: XSS
- severity: high
- source_ip: 192.168.20.10
- destination_ips: ['192.168.10.67']
- device_ids: ['iot-thermo-07']
- protocols: ['HTTP']
- event_count: 1
- confidence_mean: 0.7431233525276184
- first_seen: 2026-09-23T23:54:36.413000+00:00
- last_seen: 2026-09-23T23:54:36.413000+00:00
- model_version: 20260924T050943Z

Analyst summary

2-stage multi-stage incident from 192.168.20.10; severity high; 6 evidence items, 9/9 claims evidence-linked.

Attack chain

1. Vulnerability Scan (Reconnaissance) — 1 flows, 2026-09-23T23:44:29.429000+00:00 → 2026-09-24T00:16:11.447000+00:00; sources 192.168.20.10; targets 192.168.10.45, 192.168.20.9, iot-nas-09, iot-speaker-05; support: weak; evidence: evt_aed6f8cc3d0e48b3a80f3e23ba9a83ae, evt_c0a0c7efd8c9459ba601b6cd79a9f14b
 2. XSS (Web-Based) — 1 flows, 2026-09-23T23:54:36.413000+00:00 → 2026-09-23T23:54:36.413000+00:00; sources 192.168.20.10; targets 192.168.10.67, iot-thermo-07; support: weak; evidence: evt_81eeb4bc71e64f0e9d12522d7f6c27e4
- stage 1 → 2: moderate link, overlapping by 1295 s, shared targets none

Method: deterministic: Attack nodes PERFORMED by the alert source ordered by first_seen; other sources flooding the same target are listed as distributed_sources; other activity on the targets is context only

Other activity observed on the same targets (context only)

- XSS from 192.168.10.34 — 1 flows, 2026-09-23T23:19:45.775000+00:00 → 2026-09-23T23:19:45.775000+00:00
- Host Discovery from 203.0.113.57 — 90 flows, 2026-09-23T23:32:38.696000+00:00 → 2026-09-23T23:34:35.052000+00:00
- Dictionary Brute Force from 192.168.10.45 — 1 flows, 2026-09-23T23:34:01.595000+00:00 → 2026-09-23T23:34:01.595000+00:00
- OS Scan from 203.0.113.57 — 70 flows, 2026-09-23T23:36:38.504000+00:00 → 2026-09-23T23:39:35.218000+00:00
- Ping Sweep from 203.0.113.101 — 60 flows, 2026-09-23T23:54:55.613000+00:00 → 2026-09-23T23:55:53.659000+00:00
- ARP Spoofing from 198.51.100.12 — 80 flows, 2026-09-24T00:12:54.332000+00:00 → 2026-09-24T00:16:10.362000+00:00
- DNS Spoofing from 198.51.100.12 — 60 flows, 2026-09-24T00:17:30.008000+00:00 → 2026-09-24T00:22:05.922000+00:00

- DDoS ICMP Flood from 198.51.100.179 — 110 flows, 2026-09-24T01:06:53.540000+00:00 → 2026-09-24T01:08:22.658000+00:00
- DDoS ICMP Flood from 203.0.113.159 — 94 flows, 2026-09-24T01:06:54.321000+00:00 → 2026-09-24T01:08:22.567000+00:00
- DDoS ICMP Flood from 203.0.113.77 — 96 flows, 2026-09-24T01:06:56.141000+00:00 → 2026-09-24T01:08:21.364000+00:00
- Dictionary Brute Force from 192.168.10.23 — 1 flows, 2026-09-24T01:08:52.448000+00:00 → 2026-09-24T01:08:52.448000+00:00
- DDoS HTTP Flood from 203.0.113.174 — 86 flows, 2026-09-24T01:11:28.427000+00:00 → 2026-09-24T01:13:57.288000+00:00
- DDoS HTTP Flood from 198.51.100.150 — 81 flows, 2026-09-24T01:11:30.612000+00:00 → 2026-09-24T01:13:58.065000+00:00
- DDoS HTTP Flood from 198.51.100.28 — 70 flows, 2026-09-24T01:11:34.856000+00:00 → 2026-09-24T01:13:54.542000+00:00
- Vulnerability Scan from 198.51.100.28 — 1 flows, 2026-09-24T01:12:01.583000+00:00 → 2026-09-24T01:12:01.583000+00:00
- DoS HTTP Flood from 198.51.100.28 — 1 flows, 2026-09-24T01:12:52.336000+00:00 → 2026-09-24T01:12:52.336000+00:00
- DoS HTTP Flood from 203.0.113.174 — 1 flows, 2026-09-24T01:13:51.961000+00:00 → 2026-09-24T01:13:51.961000+00:00
- Dictionary Brute Force from 203.0.113.194 — 90 flows, 2026-09-24T03:04:21.885000+00:00 → 2026-09-24T03:10:47.691000+00:00

Evidence-backed claims

- ■ Alert alr_aa8e3fe4c88c4a1890700820da043650: 1 flows from 192.168.20.10 predicted as XSS (mean confidence 0.74) between 2026-09-23T23:54:36.413000+00:00 and 2026-09-23T23:54:36.413000+00:00. evidence: evt_81eeb4bc71e64f0e9d12522d7f6c27e4
- ■ Stage 1: Vulnerability Scan from 192.168.20.10 against 192.168.10.45, 192.168.20.9, iot-nas-09 (1 flows, 2026-09-23T23:44:29.429000+00:00 → 2026-09-24T00:16:11.447000+00:00). evidence: evt_aed6f8cc3d0e48b3a80f3e23ba9a83ae, evt_c0a0c7efd8c9459ba601b6cd79a9f14b
- ■ Stage 2: XSS from 192.168.20.10 against 192.168.10.67, iot-thermo-07 (1 flows, 2026-09-23T23:54:36.413000+00:00 → 2026-09-23T23:54:36.413000+00:00). evidence: evt_81eeb4bc71e64f0e9d12522d7f6c27e4
- ■ Stage 1 started before stage 2 but the two overlapped in time (overlap 1295s; order is by first-seen timestamp) (moderate link: shared sources ['192.168.20.10'], shared targets []). evidence: evt_aed6f8cc3d0e48b3a80f3e23ba9a83ae, evt_c0a0c7efd8c9459ba601b6cd79a9f14b, evt_81eeb4bc71e64f0e9d12522d7f6c27e4
- ■ get_related_events returned 71 records (predicted types: Benign×70, Vulnerability Scan×1; 9 destination(s)). evidence: evd_48482ff35eff423b901de321970e3be0
- ■ search_alerts returned 2 records (predicted types: Vulnerability Scan×1; 2 related alert(s): Vulnerability Scan). evidence: evd_9f0fb6efe9914038b8b7840405824e0c
- ■ search_security_events returned 19 records (predicted types: Benign×18, XSS×1; 1 destination(s)). evidence: evd_b7539c5526a8467aa86543454aef9fe9
- ■ search_alerts returned 18 records (predicted types: XSS×1, Host Discovery×1, Dictionary Brute Force×1, OS Scan×1, Ping Sweep×1; 18 related alert(s): ARP Spoofing, DDoS HTTP FI). evidence: evd_af77545a7e8e4686825b90b9d7704a8c
- ■ get_authentication_events returned 24 records (predicted types: Benign×11, Port Scan×5, DNS Spoofing×3, ARP Spoofing×2, Ping Sweep×1; 5 destination(s)). evidence: evd_58e3066d31cc4212a5e75f7d55d3b690

AI attack narrative

Generated by: template (LLM unavailable or narrative failed grounding validation) · model: n/a · grounding validation: {"checked": false}

At 2026-09-23T23:54:36.413000+00:00, 1 network flows from 192.168.20.10 towards 192.168.10.67 were classified as XSS (Web-Based) with mean model confidence 0.74. The flow-level features AVG, HTTP, Tot size provide behavioral evidence associated with the labelled XSS class [evt_81eeb4bc71e64f0e9d12522d7f6c27e4].

Adaptive evidence collection linked the alert to related activity of the same source: stage 1 Vulnerability Scan (1 flows, weak support, 2026-09-23T23:44:29.429000+00:00 → 2026-09-24T00:16:11.447000+00:00) [evt_aed6f8cc3d0e48b3a80f3e23ba9a83ae, evt_c0a0c7efd8c9459ba601b6cd79a9f14b]; stage 2 XSS (1 flows, weak support, 2026-09-23T23:54:36.413000+00:00 → 2026-09-23T23:54:36.413000+00:00) [evt_81eeb4bc71e64f0e9d12522d7f6c27e4]. Stage order is derived from flow timestamps; stages 1→2 are a moderate link (shared targets: none).

Other activity on the same target(s) (context, not attributed to 192.168.20.10): XSS from 192.168.10.34 (1 flows); Host Discovery from 203.0.113.57 (90 flows); Dictionary Brute Force from 192.168.10.45 (1 flows); OS Scan from 203.0.113.57 (70 flows).

Threat intelligence: Insufficient evidence — no external reputation data was obtained for the source indicator (provider not configured or unavailable).

What cannot be concluded: usernames, passwords, commands, payloads, files or process activity — Insufficient evidence from network-flow features alone.

Threat intelligence (actual API results)

Insufficient evidence — no external reputation data obtained.

MITRE ATT&CK mapping

Behavioral evidence

- AVG: z vs benign = 0.40283223001454044
- HTTP: z vs benign = 1.9791543496488753
- Tot size: z vs benign = 1.3733290096419544
- Rate: z vs benign = -0.5591421195431872
- Max: z vs benign = -0.14579685800343847
- flow_duration: z vs benign = -0.24867440006347988

Supporting evidence items

- `evd\_c5544b7beb3948e196a4f571e40c99ff` step 1 get_event_aggregates → 3 distinct attack_type values; top: Benign×109, Vulnerability Scan×2, XSS×1 (records 0/112)
- `evd\_48482ff35eff423b901de321970e3be0` step 2 get_related_events → predicted types: Benign×70, Vulnerability Scan×1; 9 destination(s) (records 71/71)
- `evd\_9f0fb6efe9914038b8b7840405824e0c` step 3 search_alerts → predicted types: Vulnerability Scan×1; 2 related alert(s): Vulnerability Scan (records 2/2)
- `evd\_b7539c5526a8467aa86543454aef9fe9` step 4 search_security_events → predicted types: Benign×18, XSS×1; 1 destination(s) (records 19/19)
- `evd\_af77545a7e8e4686825b90b9d7704a8c` step 5 search_alerts → predicted types: XSS×1, Host Discovery×1, Dictionary Brute Force×1, OS Scan×1, Ping Sweep×1; 18 related alert(s): ARP Spoofing, DDoS HTTP Flood, DDoS ICMP Flood, DNS Spoofing (records 18/18)
- `evd\_58e3066d31cc4212a5e75f7d55d3b690` step 6 get_authentication_events → predicted types: Benign×11, Port Scan×5, DNS Spoofing×3, ARP Spoofing×2, Ping Sweep×1; 5 destination(s) (records 24/24)

Knowledge graph summary

```
{
  "node_count": 78,
  "edge_count": 180,
  "by_type": {
    "Alert": 21,
    "IP": 20,
    "Attack": 23,
    "Device": 9,
    "EvidenceSet": 3,
    "Investigation": 1,
    "Behavior": 1
  }
}
```

```
},  
  "last_updated_step": 6,  
  "truncated": false  
}
```

Recommended actions

- Inspect the web-facing device's application logs for requests from the source in the alert window (not available from flow data).
- Restrict management/web interfaces of the affected IoT device to trusted networks.
- Monitor the source for follow-on activity against the scanned devices; scanning frequently precedes exploitation.
- Review exposed services on the scanned devices and close unnecessary ports.

Investigation limitations

- DEMONSTRATION DATA: the flows behind this report are synthetic placeholders generated because no CICIoT2023 files were present in DATASET_DIR. No statement in this report describes the real dataset.
- Entity and time context (IP addresses, devices, timestamps) is synthesized for CICIoT2023 flows; feature values and attack labels come from the data source recorded in each event.
- Flow features are behavioral evidence associated with the labelled class; usernames, commands, payloads, files and process activity are not available from the current evidence.
- 18 other attack-type cluster(s) from different sources were observed against the same target(s); they are reported as context, not attributed to 192.168.20.10.
- Low-support stage(s) 1 Vulnerability Scan (1 flow), 2 XSS (1 flow): fewer than 3 flows were classified with this label; this may be a model misclassification and is reported with a weak-support flag rather than asserted as an attack step.
- No external threat-intelligence data was obtained (provider not configured, indicator private/documentation range, or unavailable).

Investigation metrics

```
{  
  "steps": 6,  
  "db_queries": 6,  
  "events_retrieved": 134,  
  "llm_calls": 0,  
  "ti_lookups": 0,  
  "evidence_items": 6,  
  "claims": 9,  
  "claims_validated": 9  
}
```